



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES

Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025



MIDTERM LABORATORY ITP111 - System Administration and Maintenance 1 st Semester 2025-2026

NAME: **ARTES, MALANA, ORCASITAS**

SECTION: **4ITC**

NAME OF FACULTY: **PROF. RENZO EVANGELISTA**

DATE: **OCT 08, 2025**

Midterm Laboratory Activity 2: System Backup and Recovery Simulation

Description of the Attack

Network-based Attacks

Man-in-the-Middle

What it is (short)

A MitM attack occurs when an adversary secretly sits between two communicating parties (user ↔ server or device ↔ device), intercepts or alters messages, and then relays them so both sides believe they're talking directly to each other.

Conceptual step-by-step (non-actionable)

1. **Positioning** — the attacker places themselves on the communication path between victim A and victim B (physically or logically).
2. **Interception** — the attacker captures traffic flowing between the two endpoints (requests, responses, session tokens, etc.).
3. **Analysis** — the attacker inspects the intercepted data to determine value (credentials, session cookies, sensitive payload).
4. **Optional modification** — the attacker may alter messages (inject content, change parameters, strip security headers) before forwarding.
5. **Relay** — the attacker forwards traffic to the intended recipient so normal communication continues, minimizing suspicion.
6. **Persistence & exploitation** — attacker uses harvested data or continues the interception to maintain access (or terminates once objectives are met).

Note: The steps above describe the *logic* of the attack; I'm not describing how to carry it out.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Typical targets

- Individual users on insecure Wi-Fi or compromised devices.
- Small and large businesses (web apps, VPN users, remote workers).
- Government agencies or officials for espionage.
- Financial services (banking transactions) and e-commerce.

Common tools / techniques (high level)

- Network-level tactics: ARP spoofing/poisoning in local networks, DNS spoofing, rogue Wi-Fi access points.
- Protocol abuses: downgrading TLS/SSL, exploiting weak or misconfigured TLS, abusing unsecured HTTP.
- Credential harvesting: capturing unencrypted form submissions, session tokens, or cookies.
- Impersonation: fake certificates or compromised certificate authorities (conceptually).
- Malware that intercepts browser traffic or modifies system DNS.

Detection & mitigation (practical, defensive)

- Enforce strong encryption (TLS) and certificate pinning where practical.
- Use HSTS, secure cookies, multi-factor authentication (MFA).
- Monitor abnormal ARP/DNS activity and use network segmentation.
- Train users to avoid unknown Wi-Fi and verify HTTPS indicators.
- Deploy endpoint protection, intrusion detection systems (IDS), and certificate management monitoring.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Human-based Attacks

Phishing

What it is (short)

Phishing is a social-engineering attack where adversaries trick people into revealing sensitive information, credentials, or performing actions (clicking links, opening attachments) by impersonating trusted entities.

Conceptual step-by-step (non-actionable)

1. **Reconnaissance** — attacker researches victims (broad or targeted) to craft believable lures (spear-phishing uses detailed profiling).
2. **Lure creation** — attacker composes messages (email, SMS, social media) that impersonate trusted senders and include an action (click link, open attachment, reply with info).
3. **Delivery** — message is sent to victims (mass campaigns or targeted).
4. **Interaction** — victim clicks the link, opens attachment, or provides credentials; often redirected to a spoofed login page or asked to enable macros/download files.
5. **Exploitation** — attacker harvests credentials, installs malware, or uses the access to pivot into networks.
6. **Follow-on actions** — attacker uses stolen credentials for fraud, account takeover, lateral movement, or sells access.

Note: Steps describe the social process and consequences, not how to perform phishing.

Typical targets

- Individual consumers (credential/financial fraud).
- Employees at businesses (credential harvest to access corporate resources).
- Executives and finance teams (CEO fraud, invoice diversion).
- IT and HR staff (to obtain privileged info or password resets).
- Voters and the general public (disinformation campaigns).

Common tools/techniques (high level)



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- **Delivery channels:** email, SMS (smishing), voice calls (vishing), social media, collaboration platforms.
- **Techniques:** sender spoofing, lookalike domains, convincing templates/messages, fake login pages, malicious attachments (e.g., macro docs), URL shorteners to hide destination.
- **Automation & scaling:** mass mailing services, harvested lists of addresses, compromise of legitimate email accounts to increase trust.
- **Targeting:** spear-phishing uses public data (LinkedIn, corporate sites) to craft contextual messages; business email compromise (BEC) impersonates executives or vendors.

Detection & mitigation (defensive)

- Email security: strong spam filters, DMARC/DKIM/SPF enforcement, URL scanning, attachment sandboxing.
- User training: simulated phishing exercises and training on recognizing suspicious messages.
- Technical controls: block risky file types, disable macros, use browser protections, and implement identity protection (MFA, conditional access).
- Process safeguards: out-of-band verification for sensitive requests (e.g., wire transfers), limits on changing payment details via email.
- Incident readiness: rapid credential reset procedures, monitoring for atypical login patterns, and forensic logging.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Software-based Attacks

Malware

What it is (short)

Malware is any software designed to perform unwanted, harmful, or covert actions on a device or network (examples: ransomware, spyware, trojans, worms). Attackers use malware to steal data, maintain persistence, disrupt systems, or extort victims.

Conceptual step-by-step (non-actionable)

1. **Goal setting** — attacker defines objective (data theft, disruption, persistence, reconnaissance).
2. **Development/selection** — attacker obtains or adapts malware suited to the goal (off-the-shelf, custom).
3. **Initial delivery** — malware is delivered to the target via a vector (phishing email, infected website, removable media, software supply chain).
4. **Execution** — on the victim device the malware runs (exploitation, social engineering prompts, or user action may trigger it).
5. **Establish persistence** — malware creates mechanisms to survive reboots or remain hidden (startup entries, scheduled tasks, kernel components).
6. **Action/propagation** — malware performs its payload (encrypt files, exfiltrate data, open backdoors) and may attempt to spread laterally.
7. **Cleanup/covering tracks** — attacker may delete logs, obfuscate communications, or use anti-forensic techniques to avoid detection.

Note: This description explains the logic and lifecycle of malware; it purposely avoids actionable implementation details.

Typical targets

- Individuals (for credential theft, banking fraud).
- Enterprises and governments (esp. for espionage, ransomware).
- Critical infrastructure and utilities.
- Healthcare and educational institutions (often targeted due to legacy software and high impact).
- Software supply chains and cloud environments.

Common tools/techniques (high level)



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- Types of malware: ransomware, banking trojans, spyware/keyloggers, remote access trojans (RATs), worms, rootkits.
- Delivery vectors: phishing attachments/links, drive-by downloads from compromised websites, malvertising, infected USB/media, compromised software updates or third-party libraries.
- Evasion: code obfuscation, packing, encryption, polymorphism, living-off-the-land (using legitimate OS tools), sandbox detection.
- Command & Control (C2): encrypted channels, cloud services or social media used as signaling, domain generation algorithms (DGA) conceptually.
- Lateral movement: credential harvesting, pass-the-hash, abusing valid admin tools or misconfigured services.

Detection & mitigation (defensive)

- Use antivirus/EDR with behavior-based detection and centralized logging.
- Patch systems, minimize exposed services, apply least privilege, and restrict administrative access.
- Netzwerk segmentation, multi-factor authentication, and strong password policies.
- Backup strategy (isolated, versioned backups) and tested recovery plans for ransomware.
- Block known malicious domains/IPs, apply application whitelisting where practical, and monitor for unusual process behavior or data exfiltration patterns.
- Conduct regular threat-hunting, vulnerability scanning, and user training.

Real-world Example or Case Study



Republic of the Philippines
University of Cabuyao
(Pamantasan ng cabuyao)
COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Man-in-the-Middle (case study: DigiNotar certificate breach — 2011)

When & where: 2011 — breach of the Dutch certificate authority (CA) DigiNotar; effects primarily observed in Iran but had global impact.

Who was affected: Users of services that relied on DigiNotar certificates — notably many Iranian Gmail users who were targeted for surveillance, and any site for which fraudulent certificates were issued. The CA itself and its customers (websites, organizations) were also affected.

How it unfolded (summary):

- Attackers penetrated DigiNotar's systems and issued fraudulent TLS/SSL certificates for many high-profile domains (including Google domains and others).
- With forged certificates, attackers could perform effective Man-in-the-Middle interception of HTTPS traffic — victims' browsers would accept the forged certs as valid because they trusted the DigiNotar root.
- Iranian users of services such as Gmail were reportedly targeted: attackers used the forged certificates to impersonate Google and intercept encrypted traffic, enabling surveillance of email accounts and related credential harvesting.
- When the compromise became public, browser vendors and OS vendors revoked trust in DigiNotar's root certificate authorities; DigiNotar lost most business and later declared bankruptcy.

Outcome & impacts:

- Revocation of DigiNotar's certificate authority status by major vendors; widespread trust disruption for sites that used DigiNotar certs.
- Significant privacy and security harms to targeted users in Iran (surveillance of email).
- Business collapse of DigiNotar and a high-profile reminder that CA compromise enables large-scale MitM capabilities.

Statistics / scale (estimates & notes):

- Exact number of intercepted users is uncertain in public reporting; sources at the time reported tens of thousands of Iranian users were affected by targeted interception using forged certs.



Republic of the Philippines
University of Cabuyao
(Pamantasan ng cabuyao)
COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- The critical takeaway: compromise of a single CA enabled forged TLS certs for many domains and thus hypothesized broad MitM potential; the real-world interceptions concentrated where attackers had operational intent (e.g., Iranian targets).

Lessons learned (defensive):

- The supply chain of trust (CAs) is a single point of failure — certificate transparency, strict CA audits, and rapid revocation/monitoring reduce risk.
- Clients and browsers implemented more aggressive certificate revocation and audit behaviors after this incident.

2) Phishing (case study: John Podesta / DNC email compromise — 2016)

When & where: 2016 — United States; spear-phishing campaigns targeting Democratic Party organizations and individuals, including John Podesta (campaign chairman) and the Democratic National Committee (DNC).

Who was affected: High-profile political figures and organizations (Podesta, DNC staffers); subsequent release of stolen emails impacted political actors, campaigns, and public perception during the 2016 U.S. presidential election.

How it unfolded (summary):

- Attackers sent spear-phishing emails designed to look legitimate (one famous example was a targeted email that led to a password-reset/credential capture for John Podesta's Gmail account).
- At least one recipient (Podesta) clicked a malicious link and entered credentials on a spoofed page, enabling attackers to gain access to his email account.
- Separately, attackers gained access to DNC systems; exfiltrated emails and documents were later published publicly (e.g., released via WikiLeaks).
- U.S. intelligence agencies later assessed that state actors were involved and that leaked materials were used as part of information operations.

Outcome & impacts:

- Thousands of internal emails and documents were publicly released, generating substantial political fallout and media coverage.
- The incident was a central element in investigations into foreign influence operations in the 2016 U.S. election cycle.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- It prompted many organizations to strengthen defenses: multi-factor authentication (MFA), stricter email security policies, and improved training.

Statistics / scale (estimates & notes):

- WikiLeaks published tens of thousands of DNC-related emails and documents in 2016 (reports reference around 20,000 DNC emails released on July 22, 2016 — sources vary).
- Directly compromised accounts (e.g., Podesta's) were a small number of high-value targets, but the public release amplified impact far beyond the number of accounts.

Lessons learned (defensive):

- High-value individuals and organizations are prime targets for spear-phishing; MFA and phishing-resistant authentication are critical.
- Organizational processes (out-of-band verification for sensitive requests, rapid incident procedures) and regular phishing simulations reduce success rates.

3) Malware (case study: WannaCry ransomware — May 2017)

When & where: May 2017 — global outbreak affecting computers in many countries; major disruptions in healthcare, government, businesses, and industry.

Who was affected: Organizations and individuals across ~150 countries; notable disruptions in the UK National Health Service (NHS), Spanish telecom firms, Russian companies, and many others.

How it unfolded (summary):

- A ransomware family known as WannaCry used a worm-like capability to spread across networks by exploiting a vulnerability in Microsoft Windows (a vulnerability known as "EternalBlue," which exploited SMB protocol weaknesses).
- Once executed on a machine, WannaCry encrypted files and demanded ransom payments for decryption keys; the worm component attempted to propagate to other vulnerable hosts on the same network and across the internet.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES

Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025



- The worm spread rapidly because many systems remained unpatched against the exploited vulnerability despite Microsoft having released patches prior to the outbreak.
- A security researcher found and activated a “kill switch” domain embedded in the malware, which significantly slowed its spread; however, significant damage had already occurred.

Outcome & impacts:

- WannaCry affected hundreds of thousands of computers (commonly reported figure: over 200,000 machines) across over 100–150 countries. It caused operational disruption in hospitals (delayed procedures and appointments), businesses, government offices, and other services.
- Financial impact estimates vary; aggregated global losses (including downtime, remediation, lost productivity) are reported in the hundreds of millions to low billions of dollars range depending on the source and what’s included (lost business vs. direct remediation). Estimates differ widely across analyses.
- The incident dramatically highlighted patch-management failures, the risks of legacy systems (e.g., unsupported Windows versions), **and the potential for ransomware to disrupt critical services.**

Statistics / scale (estimates & notes):

- Widely cited figures: ~200,000 infected systems in ~150 countries (common in contemporaneous reporting).
- Financial loss estimates vary by source; some reports put the global economic impact in the hundreds of millions to several billion dollars, depending on scope and methodology. (Exact totals are disputed and vary by industry and region.)

Lessons learned (defensive):

- Patch management, timely application of vendor patches, and network segmentation are essential to limit wormy spread.
- Backups (offline/immutable), endpoint detection and response (EDR), and restricting SMB exposure to the internet reduce the impact of ransomware.
- Coordinated disclosure of exploitation tools and rapid response can curb outbreaks, but preparedness is paramount.

Impact Analysis



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Man-in-the-Middle (MitM)

Financial

- **Recovery & remediation costs:** incident response, forensic investigation, replacing compromised credentials and certificates, deploying additional TLS/PKI controls.
- **Lost revenue:** if e-commerce or payment flows are intercepted or customers avoid the service after the incident.
- **Indirect costs:** customer compensation, increased insurance premiums, costs to re-issue digital certificates or migrate to new trust providers.
- **Scale note:** amounts vary widely — from thousands for small compromises to hundreds of thousands (or more) for high-value breaches that require large PKI remediation and customer remediation.

Reputational

- **Customer trust erosion:** users who learn their traffic was intercepted may stop using a service or product.
- **Media scrutiny & credibility loss:** perception that the organization failed to protect communications (especially damaging for banks, healthcare portals, or government services).
- **Long-term brand damage:** reduced conversion rates, higher churn, difficult renewals for enterprise customers.

Operational

- **Service disruption:** temporary shutdown of services to reissue certificates, enforce new security controls, or investigate the incident.
- **Employee overhead:** diverted engineering/security staff time for containment and mitigation.
- **Third-party impacts:** partners or integrators may suspend connections until trust is restored.

Legal / Compliance

- **Regulatory exposure:** if intercepted data included personal data, regulators (e.g., GDPR authorities) may investigate and impose fines or corrective orders.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- **Contractual liabilities:** breach of SLAs or contractual security obligations leading to penalties or loss of contracts.
- **Litigation risk:** class actions or individual suits if sensitive data were exposed or misuse occurred.

Phishing

Financial

- **Direct losses:** fraudulent wire transfers, stolen funds, or paid ransoms resulting from credential compromise (e.g., BEC scams).
- **Recovery costs:** account recovery, credit monitoring for affected customers, forensic investigations, re-securing compromised systems.
- **Operational spend:** increased spending on email security, training, and identity protection.
- **Scale note:** BEC incidents have resulted in multimillion-dollar losses in many reported cases; smaller organizations may lose tens-to-hundreds of thousands.

Reputational

- **Loss of customer confidence:** customers may doubt the company's security posture after credential theft or account takeovers.
- **Public relations damage:** high-profile breaches driven by phishing get media attention and can harm brand equity.
- **Partner trust erosion:** vendors or clients may restrict engagements or demand stronger controls.

Operational

- **Downtime & productivity loss:** time spent remediating accounts, resetting passwords, and dealing with fraud investigations.
- **Business process disruption:** e.g., delays in payments, slowed customer onboarding, or paused hires while verifying identities.
- **Credential pivoting:** attackers using stolen credentials to access internal systems can cause broader operational impact (lateral movement).



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Legal / Compliance

- **Regulatory fines:** if personal data was exposed or fraud enabled data compromise, authorities may impose penalties under data-protection laws.
- **Reporting obligations:** breach notification laws may require public disclosure and regulator notification.
- **Liability for financial losses:** contractual or statutory liability if controls were inadequate and caused third-party losses.

Malware

Financial

- **Recovery & remediation:** cost of incident response, system rebuilds, malware eradication, patching, and professional services.
- **Ransom payments:** where ransomware is involved (note: paying ransom is legally and practically fraught and often discouraged).
- **Lost revenue & opportunity cost:** downtime of customer-facing services, lost sales, and recovery expenses.
- **Longer-term IT spend:** upgrades, new security tooling (EDR, backups), and insurance premiums.
- **Scale note:** major outbreaks (ransomware, destructive wipers) have produced losses ranging from thousands for small businesses to tens/hundreds of millions or more for large enterprises and critical infrastructure.

Reputational

- **Customer attrition:** clients may move to competitors if availability or data integrity is questioned.
- **Media coverage of outages/data loss:** severe incidents (healthcare outages, supply-chain attacks) can attract negative media and investor concern.
- **Supply-chain confidence:** partners may reconsider integrations or contracts after malware propagation via shared systems.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Operational

- **Significant downtime:** encrypted or destroyed systems can halt operations (e.g., hospitals cancelling procedures, manufacturers stopping production).
- **Productivity loss:** employees unable to access tools or data; business processes disrupted until restoration.
- **Supply-chain ripple effects:** outages can propagate to suppliers/customers dependent on affected systems.

Legal / Compliance

- **Regulatory penalties:** if protected data (health records, payment card data, personal data) is compromised, organizations may face fines (GDPR, HIPAA, PCI-DSS violations).
- **Lawsuits & liabilities:** customers or partners may sue for damages, especially if negligence in patching or controls is alleged.
- **Mandatory breach notifications:** legal requirements to notify regulators and affected individuals, bringing additional remediation costs and reputational exposure.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Preventive Measures & Mitigation Strategies

Man-in-the-Middle (MitM)

Technical controls

1. **Enforce strong end-to-end encryption** (TLS 1.2/1.3) — require HTTPS for all sites, disable weak ciphers/protocols, enforce HSTS and secure cookies.
2. **Mutual/Strong Authentication & Certificate Management** — use certificate pinning where feasible, automate certificate lifecycle (issuance/renewal/revocation), and monitor CT logs (certificate transparency).
3. **Network protections** — deploy encrypted VPNs for remote access, implement 802.1X for enterprise Wi-Fi, and use network segmentation and switch port security (disable unused mirror/SPAN).

Administrative controls

1. **Cryptography and PKI policy** — documented policy for key/certificate handling, acceptable cipher suites, and certificate authority vetting.
2. **Third-party/vendor security requirements** — require secure TLS configs and incident notification clauses from partners and cloud providers.
3. **Change & configuration management** — enforce hardened baseline images and controlled changes to network equipment that could introduce MitM risk.

Human-centric controls

1. **User training on safe Wi-Fi use** — avoid untrusted hotspots, verify corporate VPN before accessing sensitive services.
2. **Admin & developer training** — secure coding and TLS misuse prevention for dev teams; admins trained on PKI and certificate incidents.
3. **Phishing-resistant authentication adoption** — promote hardware tokens or platform MFA (FIDO2) to reduce value of intercepted credentials.

Framework mappings (high-level)

- **NIST CSF**: Protect (PR.DS, [PR.AC](#), [PR.PT](#)), Detect ([DE.CM](#)), Respond (RS).
- **ISO 27001**: Annex A controls — cryptography (A.10), communications security & network management (A.13/A.12), access control (A.9), supplier relationships (A.15).



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- **CIS Controls:** Apply controls for network segmentation and secure configurations (CIS: Inventory & control of network devices; Email/Web protections where TLS use interacts).

Phishing

Technical controls

1. **Email security stack:** SPF, DKIM, DMARC enforcement + inbound mail filtering (URL rewriting, attachment sandboxing).
2. **Strong identity & access controls:** MFA (prefer phishing-resistant methods — e.g., hardware tokens), conditional access policies (geolocation, device posture).
3. **Browser & endpoint protections:** block risky file types, enable URL reputation checks, and use browser isolation for untrusted pages.

Administrative controls

1. **Email & communications policy:** procedures for payment changes, vendor onboarding, and verification for financial transfers (out-of-band verification).
2. **Incident response & account compromise playbooks:** rapid credential revocation, forced password resets, and forensic investigation steps.
3. **Privileged access management (PAM):** limit standing admin privileges and require approval/workflow for privileged changes.

Human-centric controls

1. **Security awareness program:** recurring phishing simulations + role-based training (executives, finance, IT).
2. **Culture & reporting incentives:** easy “report phishing” buttons, rapid feedback loops, non-punitive reporting.
3. **Onboarding refresher & just-in-time warnings:** targeted training for new hires and contextual warnings on risky actions (e.g., changing payment details).

Framework mappings (high-level)

- **NIST CSF:** Protect ([PR.AC](#), [PR.AT](#)), Detect ([DE.CM](#)), Respond (RS.RP).
- **ISO 27001:** Annex A — human resources security (A.7), communications & operations (A.12), access control (A.9), incident management (A.16).



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- **CIS Controls:** Email & web browser protections; control for account/credential management and security awareness training (CIS Controls for secure configuration, malware defense, and user training).

Malware

Technical controls

1. **Endpoint protection & EDR:** behavior-based EDR with centralized logging and automated containment (isolate infected hosts).
2. **Patching & vulnerability management:** rapid, prioritized patching for OS and applications plus vulnerability scanning and configuration hardening.
3. **Backups & recovery:** immutable/air-gapped backups with tested restore processes; network segmentation to limit lateral spread.

Administrative controls

1. **Acceptable use & least privilege policies:** restrict install rights, use app whitelisting where practical, minimize admin accounts.
2. **Patch management policy & change windows:** documented SLAs for critical patch deployment and rollback plans.
3. **Incident response and business continuity plans:** ransomware-specific playbooks, legal/PR contacts, and predefined roles for recovery.

Human-centric controls

1. **Targeted training on malware vectors:** realistic scenarios for email attachments, removable media, and unsafe downloads.
2. **Privilege awareness for admins/business owners:** training on credential safety, shadow IT risks, and safe remote admin practices.
3. **Regular tabletop exercises:** rehearse incidents (malware outbreak, ransomware) with cross-functional teams to improve decisions under pressure.

Framework mappings (high-level)

- **NIST CSF:** Protect (PR.IP, [PR.PT](#)), Detect ([DE.CM](#)), Respond (RS.MI, [RS.CO](#)), Recover (RC.RP).
- **ISO 27001:** Annex A — operations security and malware protection (A.12), backup (A.12.3), access control (A.9), incident management (A.16).



Republic of the Philippines
University of Cabuyao
(Pamantasan ng cabuyao)
COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- **CIS Controls:** Malware defenses (EDR, software inventory, secure configurations), data recovery, and patch management (many CIS Controls map directly to these areas).

Written Report: System Security Threats – Man-in-the-Middle, Phishing, and Malware

Introduction

Overview of System Security and Purpose of the Study

In today's interconnected digital landscape, the security of information systems is paramount. Cyber threats continue to evolve, targeting individuals, organizations, and critical infrastructures. This report examines three major cybersecurity threats: Man-in-the-Middle (MITM) attacks, Phishing, and Malware. Each poses unique risks, exploiting vulnerabilities in networks, human behavior, and software systems. Understanding these threats—how they operate, real-world impacts, and effective prevention techniques—is essential for designing resilient security strategies.

Body

1. Man-in-the-Middle (MITM) Attacks

Description

A Man-in-the-Middle attack occurs when an attacker secretly intercepts and possibly alters communication between two parties who believe they are directly communicating with each other. This breach compromises confidentiality and integrity of data, often without the victim's awareness.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Case Study

- **Example:** The 2011 DigiNotar breach involved attackers intercepting and issuing fraudulent SSL certificates, enabling MITM attacks on multiple high-profile websites.
- **Impact:** Led to widespread loss of trust, compromised user data, and eventual bankruptcy of DigiNotar.

Impact

- Data theft and espionage.
- Financial loss due to fraudulent transactions.
- Reputation damage for affected organizations.

Prevention

- Use strong encryption protocols such as TLS.
- Implement certificate pinning.
- Deploy network security measures like VPNs and intrusion detection systems (IDS).
- Educate users to recognize suspicious network behavior.

2. Phishing

Description

Phishing is a social engineering attack where attackers impersonate trusted entities to deceive victims into revealing sensitive information such as passwords, credit card numbers, or installing malware.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Case Study

- **Example:** The 2016 Google and Facebook phishing scam resulted in over \$100 million stolen via fraudulent invoices sent by attackers posing as a legitimate vendor.
- **Impact:** Massive financial losses and increased awareness about phishing sophistication.

Impact

- Unauthorized access to personal and organizational accounts.
- Identity theft.
- Financial fraud and operational disruption.

Prevention

- Employee training and awareness programs.
- Use of email filtering and anti-phishing tools.
- Multi-factor authentication (MFA) for accounts.
- Verification procedures for financial transactions.

3. Malware

Description

Malware (malicious software) includes viruses, worms, ransomware, spyware, and trojans designed to damage, disrupt, or gain unauthorized access to systems.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Case Study

- **Example:** The 2017 WannaCry ransomware attack infected over 230,000 computers across 150 countries, encrypting data and demanding ransom payments.
- **Impact:** Caused widespread operational disruptions, including in healthcare, transportation, and government sectors.

Impact

- Data loss and corruption.
- Operational downtime.
- Financial ransom payments and recovery costs.

Prevention

- Regular software updates and patch management.
- Use of reputable antivirus and anti-malware solutions.
- Network segmentation and backups.
- User education on safe downloading and email attachments.

Conclusion

This study has highlighted the persistent and evolving nature of cybersecurity threats through the lenses of Man-in-the-Middle attacks, Phishing, and Malware. Each attack exploits different vulnerabilities—whether technological or human—and carries significant consequences for data integrity, confidentiality, and organizational trust.



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

Proactive security measures, including robust technical defenses and user education, are essential to mitigate these threats effectively. Organizations must adopt a comprehensive security framework combining prevention, detection, and response to safeguard their digital assets and maintain trust in the digital ecosystem.

Tables, Diagrams, and Flowcharts (Suggestions)

- Table 1: Comparison of MITM, Phishing, and Malware (attack vector, target, impact, prevention).
- Diagram 1: Flowchart of a Man-in-the-Middle attack process.
- Diagram 2: Anatomy of a Phishing email with highlighted red flags.
- Table 2: Case studies summary with incident, impact, and resolution.
- Diagram 3: Malware infection lifecycle and containment strategies.

References

(Example using APA format)

- Chen, T. M. (2017). Cybersecurity Threats and Solutions. *Journal of Information Security*, 8(3), 121-134.
- Krebs, B. (2017). The WannaCry ransomware attack. Retrieved from <https://krebsonsecurity.com>
- Symantec Corporation. (2016). Internet Security Threat Report. Retrieved from <https://symantec.com>



Republic of the Philippines

University of Cabuyao

(Pamantasan ng cabuyao)

COLLEGE OF COMPUTING STUDIES



Katapatan Mutual Homes, Brgy. Banay-banay, City of Cabuyao, Laguna 4025

- Zeltser, L. (2021). Man-in-the-Middle attacks explained. *SANS Institute*. Retrieved from <https://sans.org>